

SIEM'e GİRİŞ

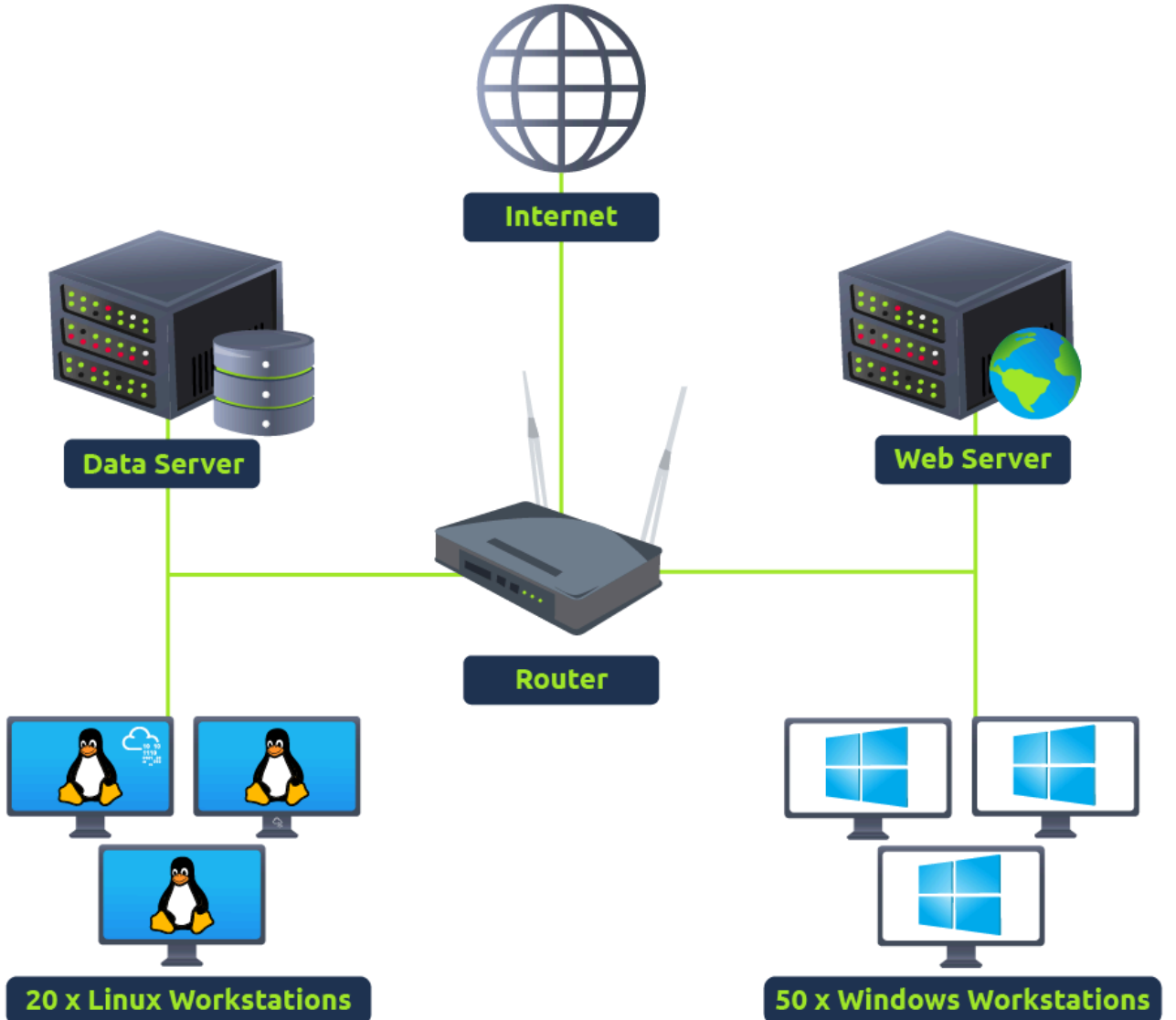
[Kaynak](#)

İÇERİK

1. Ağ İzlenebilirliği ve Log Kaynaklarının Temelleri (Logs Everywhere)
2. Neden SIEM? Dağıtık Verinin Merkezileştirilmesi ve Tespit Mimarisi
3. Log Kaynakları ve Veri Toplama Mimarisi (Log Sources and Ingestion)
4. SIEM Uyarı Süreci ve Tehdit Analizi Mimarisi (Alerting Process and Analysis)

Ağ İzlenebilirliği ve Log Kaynaklarının Temelleri (Logs Everywhere)

Bir ağ içerisindeki çoklu cihazlar, birbirleriyle ve genellikle bir **Router (Yönlendirici)** aracılığıyla internetle sürekli bir iletişim halindedir. Tipik bir kurumsal ağ mimarisi; Linux veya Windows tabanlı **Endpoint** (Uç nokta - ağa bağlı son kullanıcı cihazları), veri sunucuları ve web servislerinden oluşur.



Bu cihazların her biri, kendi içlerinde gerçekleşen aktivitelerin izini sürmemizi sağlayan loglar (kayıtlar) üretirler. Siber güvenlik bağlamında bu cihazları birer **Log Source** (Log kaynağı - sistemde oluşan olayların kaydedildiği, verinin doğduğu kök cihaz veya uygulama) olarak adlandırırız. Üretilen bu loglar, ağda meydana gelen tüm aktivitelerin dijital ayak izleridir ve hem ağ yöneticileri için **Troubleshooting** (Sorun giderme) süreçlerinde hem de güvenlik analistleri için zararlı (malicious) aktivitelerin tespitinde hayati bir rol oynarlar. Analiz stratejimizi belirlemek adına bu veri kaynaklarını, ürettikleri verinin doğasına ve sistemdeki konumlarına göre iki temel kategoriye ayırıyoruz.

Host-Centric (Uç Nokta Odaklı) Log Kaynakları

Bu kategori, doğrudan uç noktanın (host) işletim sistemi, donanımı veya üzerinde çalışan uygulamalar düzeyinde meydana gelen olayları (events) yakalar. Windows, Linux makineler ve sunucular bu tür logları üreten temel cihazlardır. İşletim sistemi düzeyindeki derinlemesine aktiviteleri analiz etmek için bu loglar kritik öneme sahiptir. Kullanıcıların dosya sistemindeki hareketleri, sistemde oturum açma veya **Authentication** (Kimlik doğrulama) girişimleri ve arka planda tetiklenen bir **Process Execution** (Süreç çalıştırma) aktivitesi tamamen uç nokta odaklı logların konusudur.

ÖNEMLİ: Özellikle Windows sistemlerde, işletim sisteminin kalbi olan kayıt defteri üzerinde bir anahtarın veya değerin eklenmesi, düzenlenmesi ya da silinmesi (Registry Key modification) ile **PowerShell** komutlarının çalıştırılması, Red Team aktivitelerini veya sistemde kalıcılık (Persistence) sağlamaya çalışan zararlı yazılım (malware) davranışlarını tespit etmek için en çok incelenmesi gereken Host-Centric loglardır.

Network-Centric (Ağ Odaklı) Log Kaynakları

Uç noktalar birbirleriyle iletişim kurduğunda veya internetteki bir web sitesine erişmek için dış ağa çıktığında, bu trafik cihazın dışına taşar ve ağ katmanında iz bırakır. **Firewall** (Güvenlik Duvarı), **IDS/IPS** (Saldırı Tespit ve Önleme Sistemleri) ve yönlendiriciler bu kategorideki logları üreten başlıca donanımlardır. Ağ odaklı loglar, sistemin dış dünya ve diğer iç sistemlerle olan topolojik ilişkisini haritalamamızı sağlar.

Bir yöneticinin veya saldırganın başlattığı **SSH Connection** (Secure Shell - komut satırı erişimi sağlayan güvenli uzak bağlantı protokolü), bir dosyanın **FTP** (File Transfer Protocol) üzerinden aktarılması veya standart HTTP/HTTPS web trafiği bu kategoriye girer. Ayrıca, şirket dışındaki bir kullanıcının kurum kaynaklarına **VPN** (Virtual Private Network) aracılığıyla erişmesi veya ağ içi dosya paylaşım aktiviteleri, ağdaki veri hareketliliğini, dış sızmaları (Data Exfiltration) ve yanal hareketleri izlemek için analiz edilmesi gereken kritik Network-Centric verilerdir.

Bu iki log kaynağı türü (Host-Centric ve Network-Centric), birleştğinde ağın tam bir görünürlüğünü sağlamak üzere saniyede binlerce log üretir. Ancak asıl teknik darboğaz, bu veriyi üretmek değil, devasa boyuttaki bu ham veriyi işleyip anlamlandırmaktır.

Yanıtların Kayboluşu: Dağıtık Log Mimarisinin Zorlukları (Answers Nowhere)

Sistemlerin log üretmesi ve güvenlik ekiplerinin bu logları inceleyerek zararlı aktiviteleri tespit etmesi kağıt üzerinde basit, doğrusal bir süreç gibi görünebilir. Gerçek dünya senaryolarında ise, log analizi süreci analistler için aşılması gereken beş temel operasyonel ve teknik zorluk barındırır:

Devasa Veri Hacmi ve Dağınık Mimari (Numerous Log Sources) Modern bir ağ, aralıksız olarak log üreten sayısız kaynaktan oluşur. Temel sorun, bu logların tek bir merkezi havuzda değil, ağın farklı köşelerindeki çeşitli cihazların kendi yerel disklerinde tutulmasıdır. Olası bir siber olay (Incident) durumunda, güvenlik analistinin bu kadar fazla cihazın yerel log dosyalarını cihaz cihaz gezerek manuel incelemeye çalışması operasyonel olarak tüketici ve verimsizdir.

Merkeziyetçilik Eksikliği (No Centralization) Loglar üretildikleri makinelerde yaşamaya devam ettiği sürece, bir analistin olay anında farklı cihazlardan log toplayabilmesi için her bir kaynağa tek tek **SSH** veya **RDP** (Remote Desktop Protocol) gibi yöntemlerle bağlanması gerekir. Kriz anında zaman, Blue Team (Savunma ekibi) için en değerli kaynaktır ve bu manuel bağlantı ile veri çekme süreci, soruşturmanın hızını ve analistin odaklanma süresini dramatik ölçüde düşürür.

Bağlam Eksikliği (Limited Context) Tekil olay günlükleri, büyük resmin sadece küçük bir parçasını gösterir; bütün bir siber saldırı hikayesini anlatamazlar. Olay müdahalesinde, farklı log kaynaklarındaki bireysel aktiviteler izole olarak incelendiğinde tamamen zararsız (benign) görünebilir. Ancak bu loglar **Correlation** (Korelasyon - farklı log kaynaklarından gelen olaylar arasında mantıksal, ip bazlı ve zamansal bağlantı kurma) işlemine tabi tutulduğunda, saldırganın gerçek hedefi ortaya çıkar.

DİKKAT: Bir sistemde standart bir dosya erişim olayı (File Access) izole olarak incelendiğinde normal bir Host-Centric aktivitedir. Ancak bu veriyi, Network-Centric loglarla korele ettiğimizde; o dosyaya erişen kullanıcının, ağdaki başka bir makineyi **Compromise** (Sistemi ele geçirme/Zafiyetten yararlanma) ettikten sonra **Lateral Movement** (Yanal Hareket - ağ içinde yetki yükselterek veya kimlik bilgisi çalarak bir cihazdan diğerine sıçrama) taktiği kullanarak hedefe ulaştığını keşfedebiliriz. Bağlam (Context) olmadan, bu gelişmiş saldırı zincirini tespit etmek imkansızdır.

Analiz Kapasitesinin Sınırları (Limited Analysis) Sistemlerin ürettiği saniyelik log hacmi (EPS - Events Per Second), bir insanın manuel olarak işleyebileceği sınırların çok ötesindedir. Analistlerin, güçlü arama motorları ve otomasyon araçları olmadan bu milyonlarca log satırı arasında anormallikleri araması, son derece kritik güvenlik olaylarının dahi insan gözünden kaçmasına neden olur.

Format Uyumsuzlukları (Format Issues) Farklı vendor'lara (üreticilere) ait cihazlar (örneğin bir donanımsal Güvenlik Duvarı ile bir Linux Web Sunucusu), logları tamamen farklı formatlarda (JSON, Syslog, XML, düz metin vb.) ve yapılarla üretir. Analistlerin tüm bu farklı

formatları ezbere bilmesi, yapısal olmayan bu verileri zihninde ayrıştırması son derece zordur. Standartlaştırılmamış, ortak bir dile çevrilmemiş veri setiyle çalışmak analizi yavaşlatır.

Bir sonraki adımımızda, ağdaki bu dağınık, formatı belirsiz ve bağlamsız veri yığını tek bir merkezde toplayarak (Aggregation), standart bir formata dönüştüren (Normalization) ve aralarında zeka dolu bağlantılar kurarak (Correlation) yukarıdaki tüm sorunları ortadan kaldıran merkezi güvenlik analiz teknolojilerinin çalışma mantığını ve teknik entegrasyonlarını inceleyeceğiz.

Neden SIEM? Dağınık Verinin Merkezileştirilmesi ve Tespit Mimarisi

Ağdaki sayısız cihazın (sunucular, ağ cihazları, uç noktalar) kendi başlarına saniyede yüzlerce log ürettiği ve bu verinin dağınık mimaride analiz edilmesinin imkansızlığından bahsetmiştik. Bu kaotik veri selini yönetmek, anlamlandırmak ve içindeki zararlı aktiviteleri (malicious activities) bir samanlıkta iğne arar gibi değil, nokta atışı tespit edebilmek için sistemlerin kalbine kurduğumuz teknoloji **SIEM (Security Information and Event Management - Güvenlik Bilgi ve Olay Yönetimi)** sistemidir.



SIEM; farklı veri kaynaklarından gelen logları bünyesine alan, karmaşık formatları okuyan, veriyi standartlaştıran ve en önemlisi farklı sistemlerdeki hareketleri birbirine bağlayarak (korelasyon) **Detection Rules** (Tespit Kuralları) üzerinden siber tehditleri avlayan merkezi bir güvenlik zekasıdır.

Aşağıda, bir SIEM mimarisinin bir güvenlik operasyonunu nasıl yönettiğini çekirdek yetenekleri üzerinden teknik bir derinlikle inceliyoruz.

Merkezi Log Toplama (Centralized Log Collection)

Siber olay müdahalesinde (Incident Response) en kritik düşman zamandır. Cihaz cihaz gezip log toplamak (SSH/RDP bağlantıları kurmak) operasyonel bir kabustur. SIEM, bu sorunu ağdaki tüm uç noktalara (Endpoints), sunuculara ve **Firewall** (Güvenlik Duvarı) gibi cihazlara entegre olarak çözer.

Veri, log kaynaklarından SIEM merkezine temel olarak iki şekilde akar:

1. **Lightweight Agents (Hafif Ajanlar):** Doğrudan uç noktalara kurulan (Örn: Elastic Winlogbeat, Splunk Universal Forwarder) ve sistem kaynaklarını yormadan anlık olayları SIEM'e iten (push) yazılımlardır.
2. **API (Application Programming Interface):** Ajan kurulamayan bulut servisleri veya kapalı kutu ağ donanımlarından veri çekmek (pull) için kullanılır.

Tüm loglar tek bir merkezde (**Data Lake/Index**) toplanır. Artık analist, tek bir arayüzden tüm ağın nabzını tutabilir.

Verinin Yapılandırılması: Parsing ve Normalization (Ayrıştırma ve Normalizasyon)

DİKKAT: Bir Linux sunucusunun ürettiği Syslog ile, bir Windows makinesinin ürettiği XML formatındaki Event Log tamamen farklı dillerde konuşur. SIEM bu dilleri ortak bir standartta buluşturmak zorundadır.

- **Parsing (Ayrıştırma):** SIEM'e ulaşan karmaşık, ham metin (Raw Log) yığını mantıksal alanlara (fields) bölme işlemidir. Hedef IP, Kaynak Port, Kullanıcı Adı, Olay ID'si gibi bilgiler uzun bir log satırından cımbızla çekilir (genellikle RegEx kullanılarak).
- **Normalization (Normalizasyon):** Ayrıştırılan bu alanların tek ve tutarlı bir formata/şemaya oturtulmasıdır. Örneğin; bir güvenlik duvarı kaynak IP adresini `src`, Windows `SourceAddress`, Linux `src_ip` olarak üretebilir. Normalizasyon aşamasında tüm bu değişkenler, analistin tek bir dilde arama yapabilmesi için örneğin `source_ip` isimli standart bir alan adına eşitlenir.

```
# ÖRNEK: Farklı Cihazlardan Gelen Çiğ Logların Normalizasyonu
Firewall Logu : %ASA-6-302013: Built inbound TCP connection ... src
192.168.1.15
Windows Logu : <EventID>4624</EventID> ...
<IpAddress>192.168.1.15</IpAddress>

# SIEM Normalizasyon Çıktısı (Arka planda JSON/Key-Value olarak
yapılandırılır):
{
  "event_type": "network_connection / authentication",
  "source_ip": "192.168.1.15", # Ortak bir alana standardize edildi.
  "action": "allowed / success"
}
```

Yukarıdaki süreç başarıyla tamamlanmazsa (Parsing/Normalization hatası), yazacağınız korelasyon kuralları çalışmaz çünkü SIEM aradığınız verinin hangi alanda (field) olduğunu bilemez.

Log Korelasyonu (Correlation of Logs) - SIEM'in Beyni

Bireysel loglar olayların tamamını göremez. İzole incelendiğinde zararsız (benign) görünen olaylar, **Correlation** (Korelasyon) motorunda zamansal ve mantıksal bir zincirle birleştirildiğinde devasa bir siber saldırının haritasını çizebilir.

Örnek Bir Siber Olay Senaryosu (5 Dakikalık Zaman Dilimi):

1. *Haris*, daha önce hiç kullanmadığı yabancı bir IP adresinden **VPN** aracılığıyla ağa giriş yapar.
2. *Haris*, ortak ağ sürücüsündeki (Shared Drive) bazı kritik belgelere arka arkaya erişim sağlar.
3. *Haris*'in makinesinde bir **PowerShell** betiği (script) çalıştırılır.
4. İlgili sistem, dış ağdaki bilinmeyen bir IP adresine şüpheli bir veri transferi (Outbound network connection) başlatır.

Teknik Analiz ve Korelasyon Mantığı: Bir SOC (Security Operations Center) analisti tek bir olay günlüğüne bakarak sadece "Başarılı VPN girişi" veya "Dosya Okuma" görür. Bu normaldir. Ancak SIEM, bu 4 adımı bir korelasyon kuralına sokar:

Kod snippet'i

```
# Kavramsal Bir SIEM Korelasyon Sorgusu (Örn: Splunk SPL)
index=vpn action=success user=Haris
| join type=inner user [search index=file_share action=read | stats count by
user, file_name]
| join type=inner host [search index=sysmon EventCode=1
Image="*powershell.exe"]
| join type=inner host [search index=firewall action=allowed
direction=outbound]
```

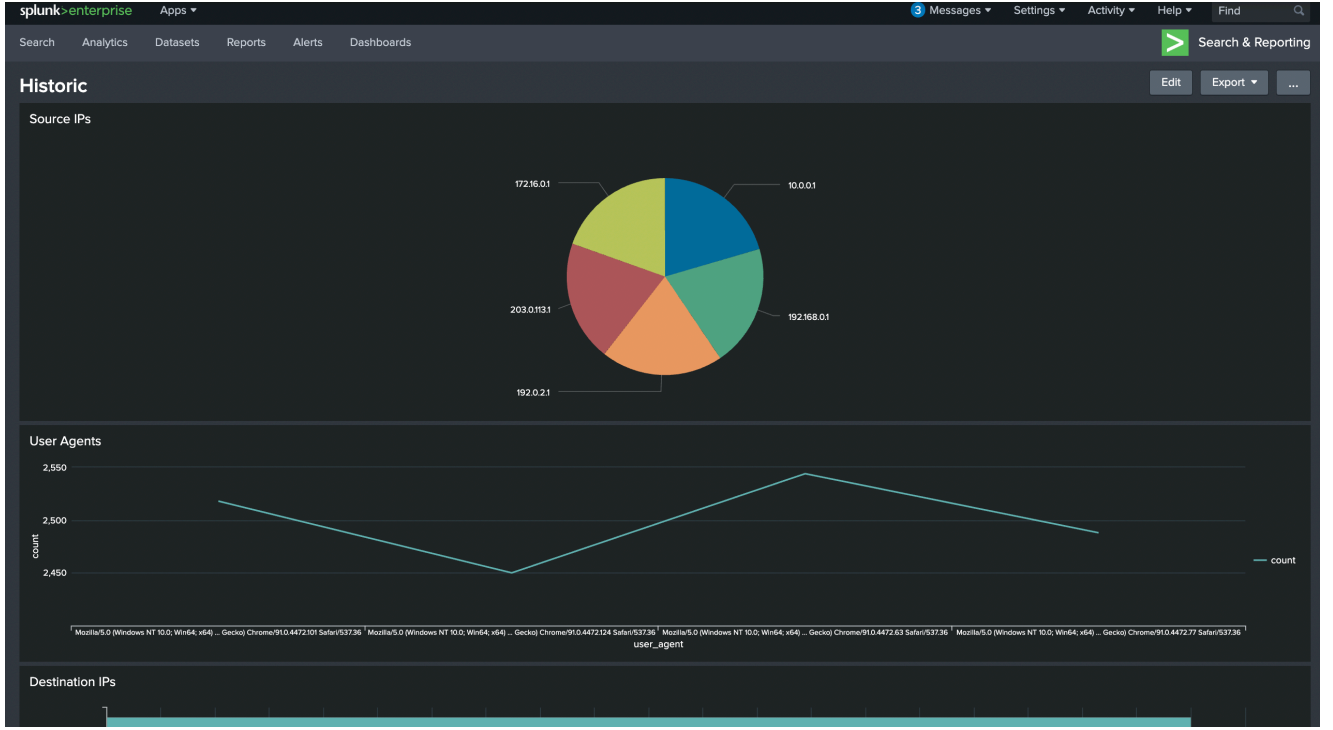
Yorum: Bu korelasyon sonucu analiste şu hikayeyi verir: Haris'in VPN kimlik bilgileri büyük ihtimalle **Compromised** (Saldırgan tarafından ele geçirilmiş) durumdadır. Saldırgan sisteme girmiş, kritik belgeleri bulmuş, muhtemelen bilgileri arşivlemek için PowerShell kullanmış ve ardından bu verileri dışarıdaki kendi C2 (Command & Control) sunucusuna göndererek bir **Data Exfiltration** (Veri Sızdırma) operasyonu gerçekleştirmiştir.

Gerçek Zamanlı Uyarı (Real-time Alerting)

Korelasyon motoru sürekli olarak arka planda çalışır. Eğer yukarıdaki gibi önceden tanımlanmış şartlar (conditions) sağlanırsa, SIEM bir **Alert** (Uyarı) üretir (Triggered). Bu uyarılar, analistlerin ekranına anlık olarak düşer. SIEM'ler kutudan çıktığında (out-of-the-box) varsayılan kurallarla gelse de, kuruma özel saldırı vektörlerine karşı Blue Team mühendisleri kendi ihtiyaçlarına göre özel (Custom) kurallar yazarak savunmayı olgunlaştırırlar.

Gösterge Panelleri ve Raporlama (Dashboards and Reporting)

SIEM tarafından toplanan, normalleştirilen ve korele edilen devasa veri, teknik metinler halinde değil; **Actionable Insights** (Eyleme Geçilebilir İlgörüler) sunan görsel **Dashboard**'lar (Gösterge Panelleri) üzerinden analiz edilir.



Bir SIEM Dashboard'u, ağın ve güvenlik durumunun merkezi izleme monitörüdür. Genellikle şunları içerir:

- **Alert Highlights (Öne Çıkan Uyarılar):** Ciddiyet (Severity) seviyesine göre (Kritik, Yüksek, Orta) tetiklenmiş kurallar.
- **List of Failed Login Attempts (Başarısız Giriş Denemeleri):** Brute-Force (Kaba Kuvvet) saldırılarını veya Parola Püskürtme (Password Spraying) aktivitelerini tespit etmek için.
- **Events Ingested Count (İçeri Alınan Olay Sayısı - EPS):** Sistem sağlığını izlemek için hayati bir metriktir (Veri akışı aniden kesilirse ajanlar çökmüş olabilir).
- **Top Domains Visited (En Çok Ziyaret Edilen Alan Adları):** Ağ içindeki botnet iletişimlerini (DGA - Domain Generation Algorithm) veya zararlı dış bağlantıları tespit etmek için.

ÖNEMLİ: Gelişmiş bir SIEM mimarisi sadece bunlarla sınırlı kalmaz. **Threat Intelligence** (Tehdit İstihbaratı - IOC'lerin sisteme otomatik entegrasyonu), uzun vadeli veri saklama politikaları (Data Retention) ve anlık milyonlarca satırda avcılık yapmayı sağlayan güçlü arama (Threat Hunting) kapasiteleri sunar.

Log Kaynakları ve Veri Toplama Mimarisi (Log Sources and Ingestion)

Bir ağ altyapısındaki her cihaz (sunucular, yönlendiriciler, uç noktalar), üzerinde gerçekleştirilen en ufak bir aktivitede bile —bir web sitesinin ziyaret edilmesi, **SSH** (Secure

Shell - Güvenli uzaktan erişim protokolü) bağlantısı kurulması veya bir kullanıcının kendi iş istasyonunda oturum açması gibi— bir log (olay günlüğü) üretir. Bu loglar, siber güvenlik analistleri için ağdaki "Görünürlüğün (Visibility)" temelini oluşturur. Bir saldırıyı tespit edebilmek veya sistemin sağlığını izleyebilmek için öncelikle bu dijital ayak izlerinin doğasını ve bu verilerin merkezi bir zekaya nasıl aktarıldığını anlamamız gerekir.

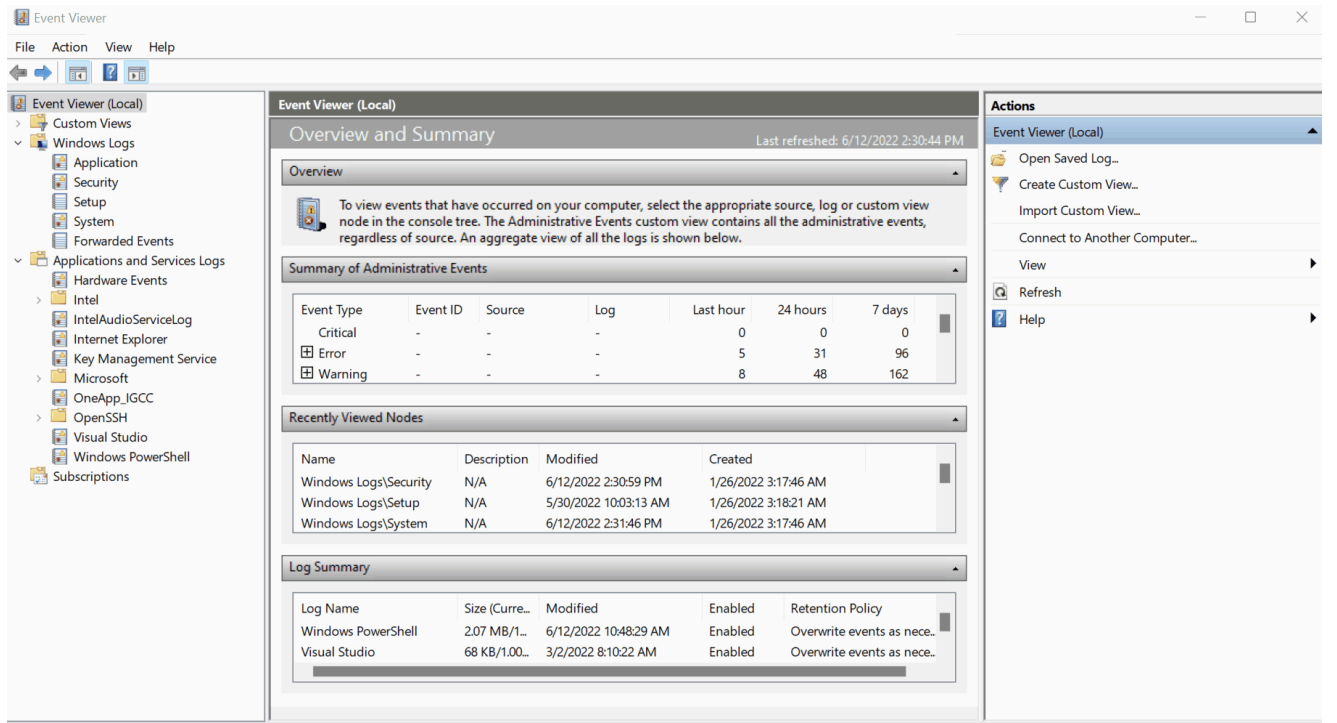
İşletim Sistemleri ve Servis Bazlı Log Kaynakları

Farklı işletim sistemleri ve servisler, mimari farklılıklarından dolayı logları kendi içlerinde özgün yapı ve formatlarda tutarlar. Sektörde en sık karşılaşılan log kaynaklarının anatomisi aşağıdadır.

Windows İşletim Sistemi Logları

Windows mimarisi, sistemde meydana gelen olayları merkezi bir yönetim aracı olan **Event Viewer** (Olay Görüntüleyici) üzerinden kayıt altına alır. Sistem, Uygulama ve Güvenlik gibi farklı kategorilerde tutulan bu logların en kritik özelliği, her olay tipine benzersiz bir **Event ID** (Olay Kimliği) atamasıdır.

Analitik Bakış: Bu yapılandırma bir SOC (Security Operations Center) analisti için hayati önem taşır. Milyonlarca satır log içerisinde örneğin "Başarılı bir oturum açma" olayını metin bazlı aramak yerine doğrudan **Event ID: 4624** üzerinden sorgulamak, hem tespit kurallarını (Detection Rules) yazmayı kolaylaştırır hem de SIEM (Security Information and Event Management) platformlarında korelasyon performansını artırır. Bu loglar, genellikle **.evtx** formatında tutulur ve kurumsal bir ortamda analizin merkezileştirilmesi için doğrudan SIEM çözümüne yönlendirilir.



Linux İşletim Sistemi Logları

Windows'un merkezi kayıt defteri mantığının aksine Linux, her servisin veya bileşenin loglarını genellikle **/var/log** dizini altında ayrı metin dosyaları olarak (çoğunlukla düz metin formatında) depolar. Kritik Linux log dizinleri ve güvenlik bağlamındaki önemleri şunlardır:

- **/var/log/httpd** veya **/var/log/apache2**: Web sunucusuna gelen HTTP Request (İstek) / Response (Yanıt) trafiklerini ve sunucu hatalarını içerir. Web tabanlı saldırıların (SQL Injection, XSS, Directory Traversal) tespit edildiği birincil kaynaktır.
- **/var/log/cron: Cron Jobs** (Zamanlanmış görevler) ile ilgili olayların tutulduğu dosyadır. *Red Team / Saldırgan perspektifinde*: Bir sisteme sızıldıktan sonra kalıcılık (Persistence) sağlamak için en çok istismar edilen noktalardan biri zamanlanmış görevlerdir. Bu log dosyasındaki şüpheli veya bilinmeyen görev eklemeleri doğrudan bir uzlaşma (Compromise) belirtisi (IOC) olabilir.
- **/var/log/auth.log** (Debian/Ubuntu) ve **/var/log/secure** (RHEL/CentOS): Doğrudan kimlik doğrulama süreçlerini kaydeder. Bir sisteme yönelik SSH Brute-Force (Kaba kuvvet) saldırıları, yetki yükseltme (**su** veya **sudo** komutu kullanımları) denemeleri bu dosyadan analiz edilir.
- **/var/log/kern**: Doğrudan çekirdek (Kernel) seviyesindeki olayları kaydeder. Donanım hatalarının yanı sıra, sisteme enjekte edilmeye çalışılan **Rootkit**'lerin veya şüpheli çekirdek modüllerinin (Kernel Modules) tespiti için incelenir.

Örnek Bir Linux Cron Log Analizi:

```
May 28 13:04:20 ebr crond[2843]: /usr/sbin/crond 4.4 dillon's cron daemon,
started with loglevel notice
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-
hourly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-
daily)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-
weekly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-
monthly)
Jun 13 07:46:22 ebr crond[3592]: unable to exec /usr/sbin/sendmail: cron
output for user root job sys-daily to /dev/null
```

Çıktı Yorumu:

- Log yapısı sırasıyla; **Tarih/Saat** (May 28 13:04:20), **Hostname** (ebr), **Servis ve PID** (crond[2843]) ve **Mesaj** gövdesinden oluşur.
- İlk satırlarda root kullanıcısına ait saatlik, günlük ve haftalık sistem görevlerinin çalıştığını görüyoruz.
- Son satırdaki (unable to exec /usr/sbin/sendmail) hata mesajı kritiktir. Cron, çalıştırdığı görevin çıktısını (output) yapılandırma gereği ilgili kullanıcıya mail atmaya çalışmış, ancak sunucuda **sendmail** servisi bulunmadığı veya çalışmadığı için bu işlemi gerçekleştirememiştir. Bir saldırı senaryosunda, saldırganın eklediği zararlı bir cron job

hata verirse, bu tür `unable to exec` hataları şüpheli bir betiğin veya binary dosyasının tespit edilmesini sağlayabilir.

Web Sunucusu Logları (Apache)

Web sunucuları, dış dünya ile iç ağ arasındaki en kritik sınırdır. Sisteme giren ve çıkan tüm isteklerin izlenmesi, potansiyel web saldırı girişimlerinin anomali tespiti için elzemdir.

Örnek Bir Apache Erişim (Access) Log Analizi:

Plaintext

```
192.168.21.200 - - [21/March/2022:10:17:10 -0300] "GET /cgi-bin/try/
HTTP/1.0" 200 3395 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758.102 Safari/537.36"
127.0.0.1 - - [21/March/2022:10:22:04 -0300] "GET / HTTP/1.0" 200 2216 "-"
"curl/7.68.0"
```

Çıktı Yorumu ve Güvenlik Bağlamı:

1. İlk Satır (Dış Erişim veya Ağ İçi Erişim):

- **Kaynak IP (192.168.21.200):** İsteği yapan makine.
- **Zaman Damgası ([21/March/2022:10:17:10 -0300]):** İsteğin yapıldığı tam an. Korelasyon için hayati önem taşır.
- **HTTP Metodu ve Hedef ("GET /cgi-bin/try/ HTTP/1.0"):** Analistin dikkat etmesi gereken en kritik yer. `/cgi-bin/` dizini genellikle web sunucularında executable (çalıştırılabilir) scriptlerin (Perl, Bash) bulunduğu yerdir. Geçmişteki ünlü **Shellshock** zafiyeti gibi saldırılar genellikle bu dizini hedef alır. Bu dizine yönelik taramalar veya erişimler bir **Enumeration** (Bilgi toplama) aşamasına işaret edebilir.
- **Durum Kodu ve Boyut (200 3395):** 200 , isteğin başarılı olduğunu (OK) gösterir. Yani 192.168.21.200 IP'si hedeflediği içeriğe ulaşmıştır. Eğer burada 403 (Forbidden) veya 404 (Not Found) görseydik, bir Dizin Tarama (Directory Bruteforcing) saldırısı olabileceğinden şüphelenebilirdik. 3395 ise dönen bayt (byte) cinsinden veri boyutudur.
- **User-Agent ("Mozilla/5.0..."):** İsteğin standart bir Windows/Chrome tarayıcısından yapıldığını belirtir. Ancak bu alan kolayca manipüle edilebilir (Spoofing).

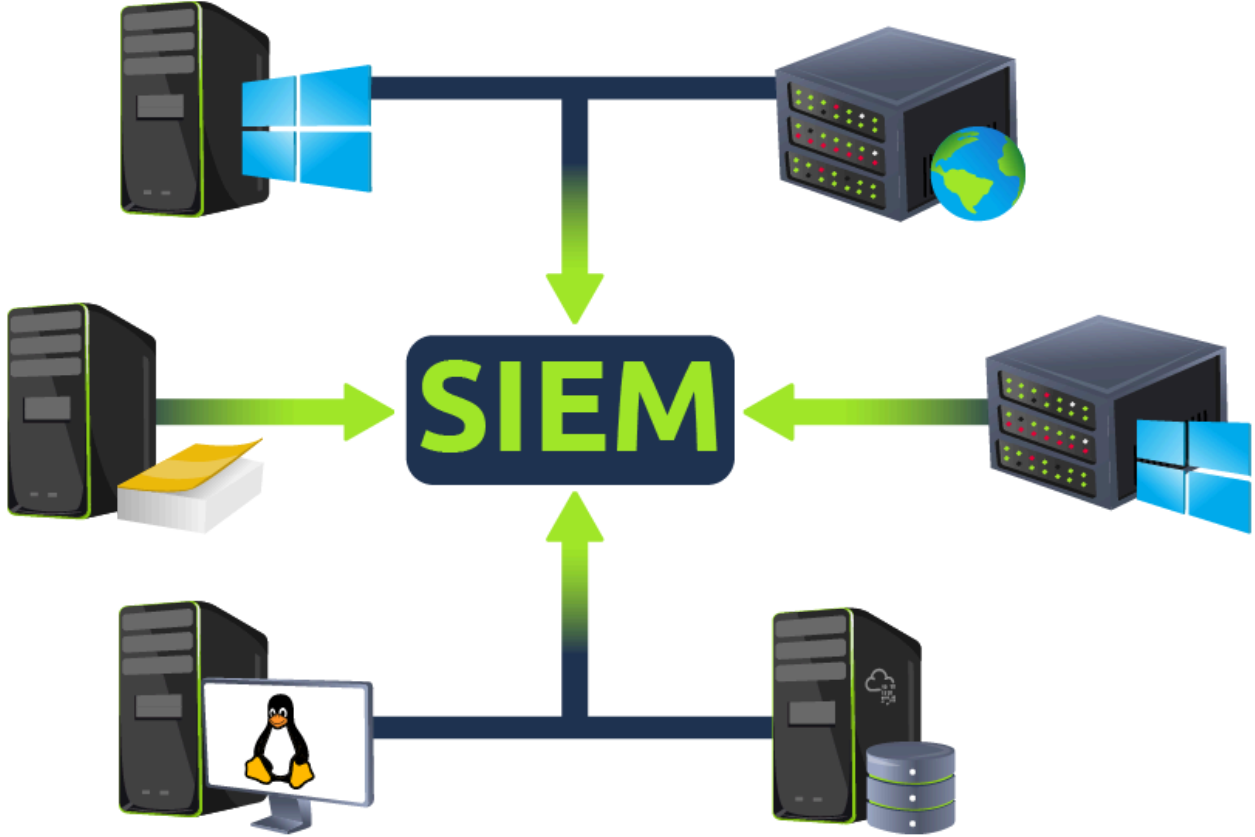
2. İkinci Satır (Localhost Erişimi):

- **Kaynak IP (127.0.0.1):** İstek doğrudan web sunucusunun kendi içinden yapılmıştır.
- **User-Agent ("curl/7.68.0"):** Bir tarayıcı yerine komut satırı aracı olan **cURL** kullanılmıştır. *Güvenlik Perspektifi:* Eğer sunucuda yetkili bir sistem yöneticisi kendi testlerini yapmıyorsa, 127.0.0.1 üzerinden gelen bir `curl` isteği; sunucuya zaten sızılmış (Post-Exploitation) ve saldırganın içeriden yerel servislere erişmeye

çalıştığına veya bir **SSRF** (Server-Side Request Forgery) zafiyetinin istismar edildiğine dair güçlü bir işaret olabilir.

Log Ingestion (Veri Alımı / İçeri Aktarma) Yöntemleri

Yüzlerce cihazın yerel disklerinde depolanan bu değerli veriler, tek başlarına analiz edilemeyecek kadar dağınıktır. Bu logların toplanıp, formatlarının standardize edilerek (Normalization) merkezi bir SIEM (Örn: Splunk, Elastic, QRadar) platformuna aktarılması işlemine **Log Ingestion** denir. Sektör standardı haline gelmiş dört temel veri alım yöntemi şunlardır:



1. Agent (Ajan) / Forwarder (Yönlendirici) Doğrudan veriyi üreten **Endpoint**'e (Sunucu veya Son Kullanıcı Cihazı) kurulan hafif (lightweight) yazılımlardır. (Örn: Splunk Universal Forwarder, Elastic Filebeat/Winlogbeat). *Neden Kullanılır?* Sadece belirtilen dizinlerdeki veya belirtilen Event ID'lerdeki önemli logları okur, gerekirse şifreler (TLS üzerinden) ve SIEM sunucusuna iletir. Ağ bağlantısı koptuğunda logları cihazda önbelleğe (buffer) alıp bağlantı geldiğinde göndermeye devam edebildikleri için veri kaybını önleyen en güvenilir yöntemdir.

2. Syslog Protokolü Ağ cihazları (Firewall, Router, Switch), web sunucuları veya veritabanları tarafından gerçek zamanlı (real-time) olay mesajlarını merkezi bir log sunucusuna göndermek için kullanılan endüstri standardı bir protokoldür. Genellikle UDP 514 veya TCP 514 portlarını kullanır. **DİKKAT:** Syslog varsayılan olarak veriyi düz metin (plaintext) ve şifresiz gönderir. Modern mimarilerde bu zafiyeti kapatmak için TLS üzerinden çalışan güvenli Syslog (Syslog-ng veya Rsyslog) yapılandırmaları tercih edilmelidir. Aksi takdirde ağ içi bir MITM (Ortadaki Adam) saldırısıyla loglar okunabilir veya manipüle edilebilir.

3. Manual Upload (Manuel Yükleme) Canlı veri akışının olmadığı veya ağdan izole edilmiş sistemlerin analizinde kullanılır. Örneğin; bir Incident Response (Olay Müdahale) senaryosunda, internete kapalı ve izole edilmiş (Quarantined) enfekte bir makinedeki .evtx Windows log dosyaları USB bellek vb. yollarla alınır ve SOC analisti tarafından Splunk veya ELK gibi platformlara çevrimdışı (offline) olarak yüklenerek hızlıca analize dahil edilir.

4. Port-Forwarding (Port Yönlendirme ve Dinleme) SIEM çözümünün spesifik bir TCP veya UDP portunu (Listening Port) dinlemeye aldığı mimaridir. Uç noktalar veya ağ cihazları, herhangi bir ajan kurulumuna ihtiyaç duymadan yapılandırmaları üzerinden kendi loglarını doğrudan bu spesifik porta yönlendirir. Genellikle ajan kurulamayan kapalı kutu (appliance) cihazların (Örn: Donanımsal güvenlik duvarları veya IoT cihazları) SIEM'e entegre edilmesi için kullanılan pratik bir yöntemdir.

SIEM Uyarı Süreci ve Tehdit Analizi Mimarisi (Alerting Process and Analysis)

Bir önceki aşamada dağınık logların merkezi bir SIEM (Security Information and Event Management) sisteminde nasıl toplanıp standartlaştırıldığını inceledik. Ancak toplanan bu veriler tek başına anlamsız bir yığından ibarettir. SIEM'in gerçek gücü ve "beyni", bu veriler üzerinde çalışan ve tehditleri anında yakalayan **Detection Rules** (Tespit Kuralları) mimarisinde yatar. Bir siber güvenlik analistin (SOC Analyst) olaylara zamanında müdahale edebilmesi tamamen bu kuralların mantıksal kusursuzluğuna bağlıdır.

Tetiklenen Uyarıların Arka Planındaki Matematik (Behind the Triggered Alerts)

SIEM sistemlerinin arka planındaki "sihir", aslında son derece spesifik durumları arayan mantıksal ifadeler (boolean logic) silsilesidir. Bir kural, belirli şartlar bir araya geldiğinde eşleşir ve bir uyarı (Alert) tetikler. Bu kuralların yazımında bağlam ve eşik (threshold) değerleri hayati önem taşır.

Tipik ve kritik tespit kuralı senaryolarına analitik bir bakış:

- **Senaryo 1:** *Eğer bir kullanıcı 10 saniye içinde 5 başarısız giriş denemesi (Failed Login) yaparsa, "Çoklu Başarısız Giriş Denemesi" uyarısı tetikle.*
 - **Teknik Anlamı:** Bu, klasik bir **Brute-Force** (Kaba Kuvvet) veya **Password Spraying** (Parola Püskürtme) saldırısının imzasıdır. Burada zaman aralığı (10 saniye) kuralın kalbidir. Eğer bu aralık verilmezse, bir ay içindeki 5 hatalı giriş de alarm üretir ve bu analiz sistemini çökertecek bir gürültü (noise) yaratır.
- **Senaryo 2:** *Çoklu başarısız giriş denemesinin hemen ardından başarılı bir oturum açma (Successful Login) gerçekleşirse alarm üret.*
 - **Teknik Anlamı:** Bu, Brute-Force saldırısının *başarıya ulaştığını* gösteren en tehlikeli uyarılardan biridir. Saldırgan artık içeridedir ve **Compromised** (Ele geçirilmiş) bir hesapla ağda hareket etmeye başlayacaktır.
- **Senaryo 3:** *Bir kullanıcı makinesine USB bellek taktığında uyarı tetikle.*

- **Teknik Anlamı:** Şirket politikalarında USB kullanımı yasaklanmışsa bu durum, içeriden gelen bir tehdidi (Insider Threat) veya fiziksel bir zararlı yazılım bulaştırma girişimini (örneğin Rubber Ducky) işaret eder.
- **Senaryo 4: Dış ağa doğru (Outbound) giden trafik > 25 MB ise "Potansiyel Veri Sızdırma (Data Exfiltration)" uyarısı tetikle.**
 - **Teknik Anlamı:** Saldırganlar sistemden veri çalarken bunları dışarıdaki kendi C2 (Command & Control) sunucularına aktarırlar. Hacim tabanlı bu kurallar, ağ anomalisini tespit etmek için kullanılır.

Bir Tespit Kuralı Pratik Olarak Nasıl İnşa Edilir? (Rule Creation Mechanics)

Bir tespit kuralının gücü, hedeflenen saldırı vektörünün teknik ayak izini (IOC - Indicator of Compromise) ne kadar iyi tanımladığınıza bağlıdır.

Kullanım Durumu (Use-Case) 1: Anti-Forensics (İz Kaybettirme) Tespiti Saldırganlar, **Post-Exploitation** (Sistemi istismar edip ele geçirdikten sonraki aşama) adımlarında sistemde bıraktıkları izleri silmek için Windows Olay Günlüklerini (Event Logs) temizleme eğilimindedir. Windows mimarisinde bir kullanıcı logları sildiğinde veya temizlediğinde sistem otomatik olarak **Event ID 104** (Olay Kimliği 104) üretir.

Bunu tespit edecek mantıksal kural şu şekilde oluşturulur:

```
KURAL: EĞER (Log Source == "WinEventLog") VE (EventID == 104)
SONUÇ: TETİKLE "Kritik Uyarı: Olay Günlüğü Temizlendi (Event Log Cleared)"
```

Yorum: Bu kural eşleştiği an analist bilmelidir ki; yüksek yetkilere (Administrator/SYSTEM) sahip biri veya bir zararlı yazılım aktif olarak adli bilişim (Forensics) sürecini sabote etmektedir. Bu, doğrudan "Sistemde saldırgan var" anlamına gelen yüksek ciddiyetli (High Severity) bir durumdur.

Kullanım Durumu (Use-Case) 2: Durum Tespiti (Reconnaissance) ve Yetki Kontrolü Saldırganlar **Privilege Escalation** (Yetki Yükseltme) işlemi yaptıktan hemen sonra, yeni yetkilerini kontrol etmek için komut satırında `whoami` (Ben kimim?) komutunu çalıştırırlar. Standart bir kurumsal kullanıcının bu komutu çalıştırması son derece olağandışıdır.

Bu davranışı yakalamak için Windows süreç oluşturma loglarına (Process Creation) bakmalıyız:

1. **Log Source:** WinEventLog (Özellikle Security logları).
2. **Event ID:** Yeni bir süreç başladığında/komut çalıştırıldığında Windows **Event ID 4688** üretir.
3. **Hedef Alan (Field):** Çalıştırılan uygulamanın adı `NewProcessName` (veya SIEM'in normalizasyon şemasına göre `process_name`) alanında tutulur.

Mantıksal Kural:

```
KURAL: EĞER (Log Source == "WinEventLog") VE (EventCode == 4688) VE  
(NewProcessName İÇERİYORSA "whoami")  
SONUÇ: TETİKLE "Yüksek Uyarı: whoami Komut Çalıştırması Tespit Edildi"
```

ÖNEMLİ (Alan-Değer Eşleşmesinin Rolü): Önceki konularda işlenen "Normalizasyon (Normalization)" kavramı tam da burada hayati bir rol oynar. Eğer SIEM sisteminiz ham logu düzgün ayrıştırıp (Parsing) komutun adını `NewProcessName` alanına (field) değer (value) olarak atayamazsa, yazdığınız bu kural `whoami` komutunu hiçbir zaman göremez ve saldırıyı kaçırsınız.

Uyarı İnceleme ve Olay Müdahale İşlemleri (Alert Investigation)

Kural tetiklenip SIEM paneline (Dashboard) düştüğünde işin analitik kısmı başlar. Analist, sadece uyarının başlığına bakarak karar vermez; uyarıyla ilişkili olayları (events) ve ağ akışlarını (flows) derinlemesine inceler.

Bu incelemenin sonucunda olay iki ana kategoriye ayrılır ve farklı aksiyonlar gerektirir:

1. False Positive (Yanlış Pozitif - Hatalı Alarm): Durum incelenir ve etkinliğin zararlı olmadığı, örneğin bir sistem yöneticisinin bakım yaparken `whoami` çalıştırdığı tespit edilir.

- **Aksiyon (Tuning):** Benzer hatalı alarmların SOC ekibinde "Alarm Yorgunluğu (Alert Fatigue)" yaratmaması için kural iyileştirilir (Tuning). Örneğin kurala `VE (Kullanıcı != "Admin_Ahmet")` şeklinde bir istisna (Exception) eklenir.

2. True Positive (Gerçek Pozitif - Onaylanmış Tehdit): İnceleme sonucunda zararlı bir aktivite olduğu kesinleşirse anında **Olay Müdahale (Incident Response)** prosedürleri devreye sokulur:

- **İletişim:** Olayın yaşandığı varlığın (Asset) sahibi ile iletişime geçilip bu işlemin onların bilgisi dahilinde olup olmadığı doğrulanır.
- **İzolasyon (Containment):** Zararlı aktivite onaylandığında (Örn: Saldırganın içeride olduğu veya fidye yazılımının çalışmaya başladığı kesinleştiğinde), enfekte olan uç nokta (Endpoint) derhal ağdan izole edilir. Böylece saldırganın diğer makinelere sıçraması (Lateral Movement) engellenir.
- **Ağ Engelleme (Blocking):** Eğer saldırı dışarıdan bir IP'den geliyorsa veya veri sızdırma işlemi dışarıdaki bir IP'ye yapılıyorsa, bu şüpheli IP adresi Firewall (Güvenlik Duvarı) üzerinden acil olarak bloklanır.